authenticating someone using just an identifier seems impossible, but that's exactly what browser cookies are. Browser cookies are an identifier created by a website that's stored in the browser and meant to be returned to the website the next time the user visits. This is how sessions are maintained between individual browser clicks since HTTP, the protocol underlying the web, is stateless and can't maintain sessions on its own. Figure 3.5 shows the interactions between Alice and an identifier-only authentication service.

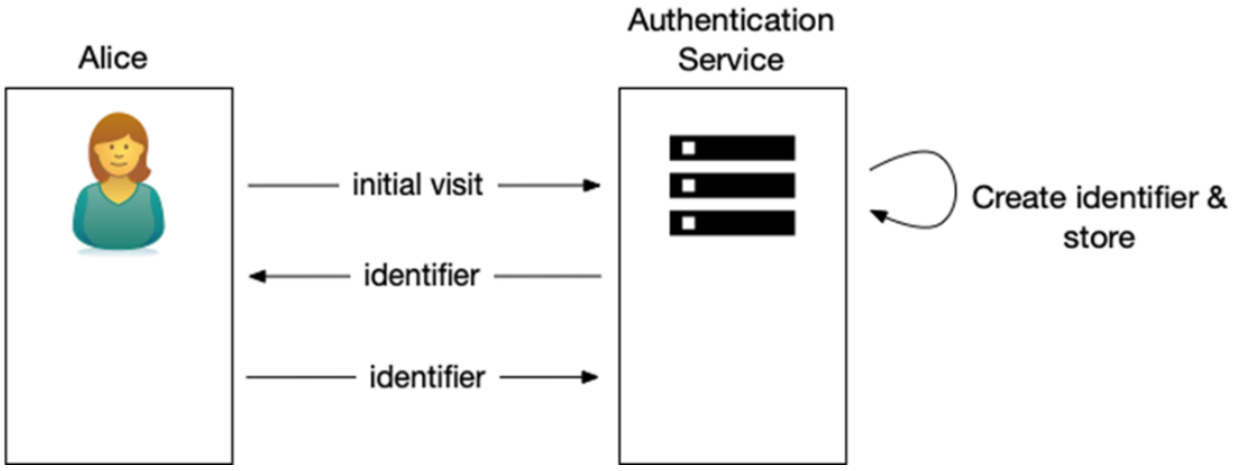


Figure 3.5 Identifier-only authentication flow. When Alice first visits, the authentication service creates and stores an identifier (such as a session cookie) and returns it to her client. For subsequent requests, Alice's client presents this identifier to indicate her relationship with the system. No additional authentication factors are used. This approach relies entirely on the secrecy of the identifier, making it vulnerable to interception, guessing, or reuse if not properly secured with transport encryption and randomness.

Upon Alice's initial visit, the service returns an identifier to Alice, that she resends each time she returns. Identifier-only authentication treats the identifier as a shared secret; it's only secure when you can be reasonably sure that the identifier is not easily guessed or stolen. Consequently, public identifiers, like email addresses, don't work. This is the primary disadvantage of identifier-only authentication. Anyone who can guess or intercept the identifier can hijack the relationship and impersonate the requester. This is one reason TLS is vital for secure web interactions. TLS encrypts the channel to maintain the confidentiality of the communications, including any identifiers that are exchanged in the HTTP headers.